Informática Forense y Respuesta ante Incidentes

Tema 3. Adquisición de evidencias digitales

Índice

Esquema

Ideas clave

3.1. Introducción y objetivos

3.2. Acotando la escena del crimen

3.3. Funciones hash

3.4. Fase de preparación

3.5. Conceptos previos

3.6. Recolección y adquisición de evidencias digitales

3.7. Procedimientos especiales de adquisición

3.8. Referencias bibliográficas

A fondo

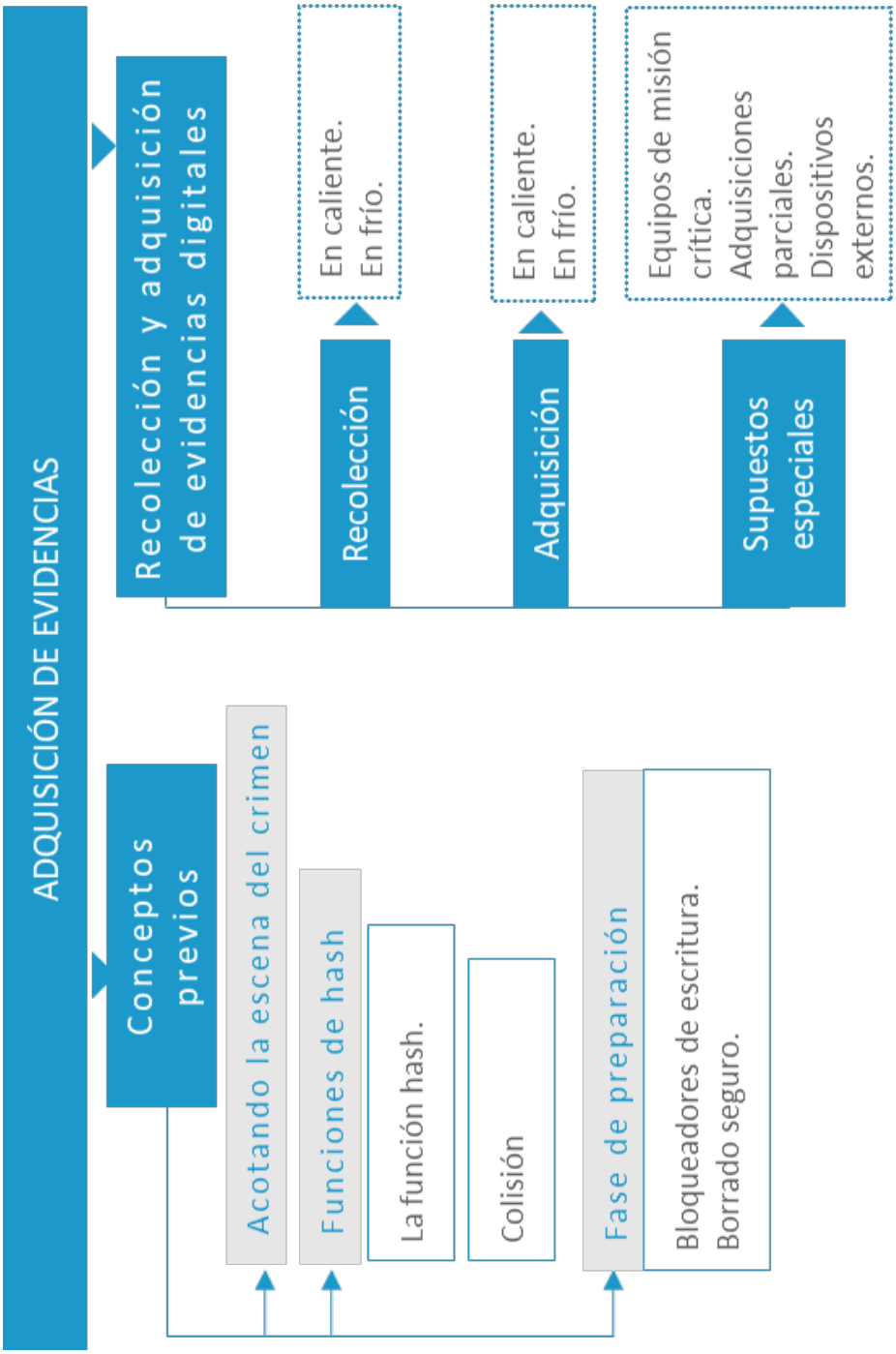
DFRWS Acquiring forensic evidence from infrastructure-as-a-service cloud computing

On the Use of Hash Functions in Computer Forensics

Directrices para la identificación, recogida, adquisición y preservación de evidencias electrónicas

Test

Esquema



© Universidad Internacional de La Rioja (UNIR)

3.1. Introducción y objetivos

En este tema vamos a tratar uno de los puntos más importantes dentro del análisis forense como es el de la adquisición de las evidencias.

Como hemos comentado anteriormente, debido a que la prueba es el elemento fundamental de juicio, en muchas ocasiones se la intenta invalidar por cuestiones de procedimiento, por lo que una correcta adquisición de ellas es sumamente importante.

Para ello, nos basaremos en todo momento en la recomendación ISO/IEC 27037:2016.

Al finalizar este tema el alumno deberá:

- Comprender perfectamente el procedimiento de adquisición de evidencias según la norma.
- Entender la casuística específica en los diferentes tipos de adquisición.
- Realizar la adquisición de manera práctica con herramientas forenses.
- Iniciar una cadena de custodia.
- Acotar debidamente la escena del crimen.

© Universidad Internacional de La Rioja (UNIR)

3.2. Acotando la escena del crimen

Cuando vamos a realizar una adquisición, lo primero que haremos será determinar sobre qué equipos o dispositivos debemos actuar. Habitualmente, el modo de trabajo será **apersonarnos** en las instalaciones en las que se nos indica que debemos hacer la adquisición (solos o, más convenientemente, acompañados de un fedatario público o testigos suficientes).

Una vez en dichas instalaciones (lo que denominamos la escena del crimen), es probable que nos encontremos gran cantidad de dispositivos informáticos o elementos capaces de almacenar información y, por tanto, de contener evidencias digitales. Una primera labor a realizar será analizar exactamente qué vamos a tener que adquirir y qué elementos no son necesarios. Esto es lo que se denomina «acotar la escena del crimen».

Escenario típico de trabajo

Un escenario habitual de trabajo en los casos vinculados a empresas es que una vez apersonados en la empresa en cuestión, se nos lleva al puesto de un empleado que, habitualmente, es la persona relacionada con el caso a examinar. En su lugar de trabajo, nos encontraremos su equipo (ordenador personal) así como ciertos dispositivos de almacenamiento (pendrives USB o discos duros). Se nos informa también que dicho ordenador está conectado a un servidor corporativo que se utiliza para almacenar ficheros o, incluso, para acceder a algún tipo de aplicación corporativa que centraliza su información en un servidor de bases de datos.

El correo probablemente estará en un servicio de la nube como Google Workspace o Microsoft Office 365. Además, es probable que comparta un

© Universidad Internacional de La Rioja (UNIR)

espacio de almacenamiento en la nube con alguna de estas plataformas anteriores.

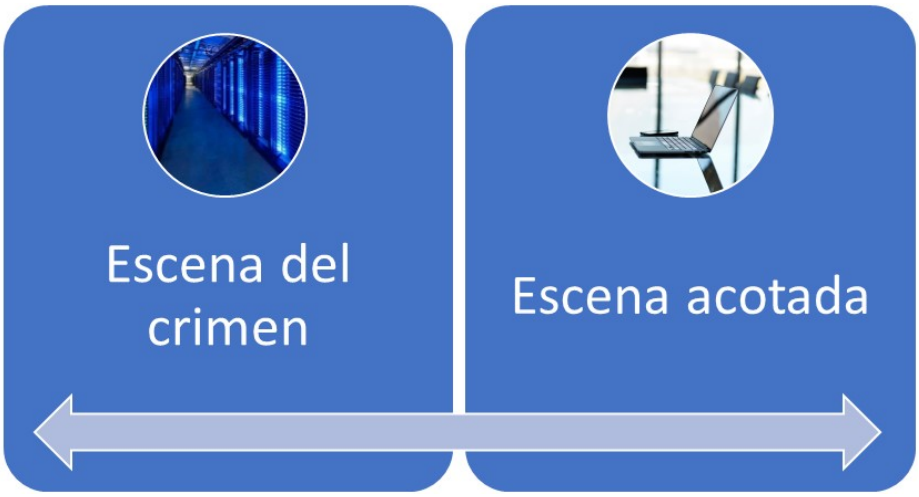


Figura 1. Acotando la escena del crimen. Fuente: elaboración propia.

Para acotar la escena del crimen, lo que vamos a hacer es responder a dos preguntas, a saber:

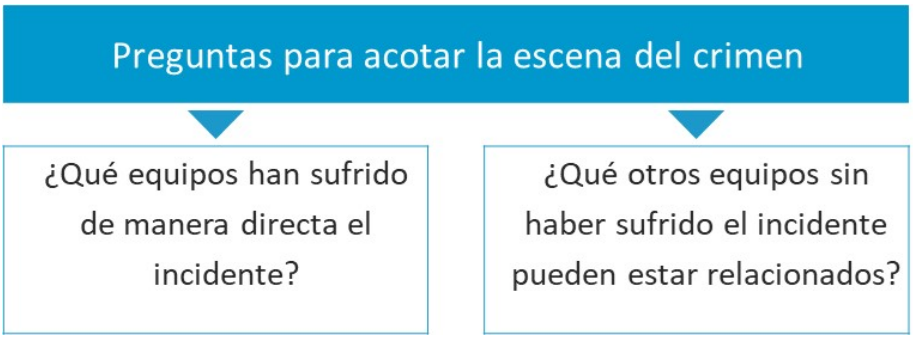


Figura 2. Preguntas para acotar la escena del crimen. Fuente: elaboración propia.

Ejemplo: acotando la escena en un caso de *malware*

En un incidente por la infección por algún tipo de *malware* de una organización, tendríamos:

© Universidad Internacional de La Rioja (UNIR)

¿Qué equipos han sufrido de manera directa el incidente?

Los equipos infectados con el *malware*.

Si ha podido infectar algún dispositivo externo, los dispositivos externos infectados (pendrives, discos duros externos, etc.).

¿Qué otros equipos, que sin haber sufrido el incidente, pueden estar relacionados?

Si ha entrado a través del correo electrónico, el servidor de correo electrónico

Los equipos de seguridad (antivirus, firewall de aplicaciones, IDS, etc.) de la red de la organización que han analizado ese correo.

© Universidad Internacional de La Rioja (UNIR)

3.3. Funciones hash

Que es la función hash

Una función o algoritmo hash es una función matemática computable mediante un algoritmo que tiene como entrada un conjunto de elementos (normalmente, la información contenida en la evidencia) y que genera como salida un conjunto de elementos de longitud finita.

Desde una perspectiva más visual, una función de hash es una función que mapea datos digitales de tamaño variable a datos digitales de tamaño fijo.



Figura 3: Funcionamiento de las funciones hash. Fuente: elaboración propia.

A nivel práctico lo que vamos a tener es una cierta cantidad de información digital (un archivo, el contenido de un disco duro o un pendrive, una cadena de texto, etc.) a la que vamos a aplicar la función hash y vamos a obtener una **cadena hexadecimal** con una longitud fija.

Propiedades de las funciones *hash*

Las principales propiedades de una función *hash* a nivel forense son:

- **Bajo coste computacional:** no consume muchos recursos y, de ese modo, podemos realizarla con cualquier equipo y en un tiempo reducido. Lo que más tiempo va a tardar a la hora de realizar un *hash* es el de lectura de toda la

© Universidad Internacional de La Rioja (UNIR)

información (por ejemplo, si es un disco duro muy grande).

- **Compresión:** la salida va a ser de unos pocos caracteres hexadecimales, con lo que es mucho más manejable que la entrada.
- **Inyectividad:** para cada entrada se genera un hash diferente. Lo ideal es que además sea único, pero hay que tener en cuenta que la entrada no está limitada mientras que la salida, al ser un conjunto finito de caracteres, sí, por lo que habrá repeticiones.
- **Unidireccionalidad:** es de un solo sentido, esto es, con una entrada A tenemos un resultado B, pero con B no podemos inferir A de nuevo.
- **Determinista:** con una entrada A la salida siempre va a ser el mismo conjunto de caracteres B.
- **Resistente (o casi) a colisiones:** resistente a colisiones quiere decir que podemos encontrar dos entradas diferentes con la misma salida. Esto es posible, en teoría, ya que en la inyectividad el conjunto de salidas es finito para un conjunto infinito de entradas. En este caso lo que vamos a tener es que, dependiendo del algoritmo, el conseguir esas dos entradas que proporcionan la misma salida es computacionalmente muy costoso o, incluso, aún no se ha conseguido (aunque en la teoría sea posible).

¿Cómo se utilizan las funciones hash en análisis forense?

Utilizaremos las funciones *hash* en análisis forense para comparar dos archivos u otros elementos de información y ver si son exactamente iguales. Si sus hash coinciden, serán idénticos; mientras que, si hay la más mínima variación, los hash serán completamente diferentes.

La inyectividad nos va a permitir que el proceso de comparación con hash sea reproducible, ya que siempre vamos a tener los mismos *hashes* al aplicar la misma entrada; y la resistencia a colisiones y unidireccionalidad nos hacen que sea un

© Universidad Internacional de La Rioja (UNIR)

mecanismo confiable.

Gracias a las funciones hash, comparando hashes, podemos:

- Descartar/señalar archivos conocidos.
- Señalar archivos relevantes.
- Buscar archivos duplicados (o, incluso, similares).
- Garantizar la no modificación de la evidencia o de las muestras obtenidas.

Tipos de funciones

hash

Como hemos mencionado, funciones hash hay muchas, pero algunas de las más típicas son:

- MD5: abreviatura de Message-Digest algorithm 5, genera salidas de 128 bits (32 caracteres hexadecimales).
- SHA o SHA1: abreviatura de Secure Hash Algorithm, genera salidas de 160 bits (40 caracteres hexadecimales)
- SHA2: segunda versión del algoritmo SHA, genera salidas de 224, 256, 384 o 512 bits.
- SHA3: tercera y última versión del algoritmo SHA. Al igual que SHA2, genera salidas de 224, 256, 384 o 512 bits.

© Universidad Internacional de La Rioja (UNIR)

Entrada	Algoritmo *Hash*	Salida
forense	MD5	e1576f172c3b126ae7a6026e8995da85
Forense	MD5	f0128cf087fa49732bf066306d5f4a6f
forense	SHA1	12fce1fcce8913c12c37e925500af2e03016289a
Forense	SHA1	da984d2a2eaa8acf2289ccbc388c812ef21c97ed
forense	SHA2-256	936eadf290e12e795165cae5486a24a97b9009303287704f4f6242d439d1e0ea
Forense	SHA2-256	d83dbbd04ed9d7272cd8548206794df45403fbfc7246f16273ae09c38152196a
forense	SHA3-256	9acebe86ba16f103ab20adf5b0fe9d9ee3b87b2d4dcd57b8b352abc5dd3ca413
Forense	SHA3-256	a76266d05884ff50fa0106c82efe72b72ebe4cb8902f363aea40ab5647573407

Tabla 1. Ejemplo de valor hash para un archivo de texto con la palabra «forense» y otro archivo con la palabra «Forense». Fuente: elaboración propia.

© Universidad Internacional de La Rioja (UNIR)

3.4. Fase de preparación

De manera previa a la adquisición, vamos a analizar los pasos previos a tener en cuenta. En este sentido vamos a ver dos procedimientos a realizar; uno, sobre el equipo a adquirir como es el bloqueo contra escritura; y otro, sobre el dispositivo sobre el que vamos a adquirir que es el borrado seguro.

Bloqueadores de escritura

En la adquisición de evidencias, vamos a intentar —en medida de lo posible— no modificar la fuente de información original que estamos adquiriendo. Para asegurarnos de dicha labor, es necesario que el dispositivo que vamos a adquirir esté —si es posible— protegido contra escritura, de modo que no podamos modificarlo, bien sean nuestros sistemas a través de los procesos propios de los sistemas operativos o bien sea nosotros de manera accidental.

Un bloqueador contra escritura es una herramienta (hardware o software) que impide la escritura sobre un dispositivo de almacenamiento.

Los **bloqueadores contra escritura por *hardware*** son dispositivos que se conectan a nuestro equipo mediante USB, Firewire o algún otro tipo de conexionado de alta velocidad, y que hacen de puente entre el elemento a bloquear (normalmente, la evidencia original) y nuestro equipo, impidiendo cualquier intento de escritura sobre el dispositivo a proteger.

Dispositivos bloqueadores contra escritura por software hay muchos, aunque algunos de los más utilizados son:

- WiebeTech – CRU (https://www.cru-inc.com/products/wiebetech/).

© Universidad Internacional de La Rioja (UNIR)

- Tableau (https://www.guidancesoftware.com/tableau).

Además, los bloqueadores contra escritura por software son programas o pequeños scripts que impiden al sistema operativo escribir sobre un determinado dispositivo o puerto (por ejemplo: bloqueando la escritura de los puertos USB).

Aunque no siempre es la opción ideal, ya que no son capaces de impedir procedimientos de escritura a bajo nivel, sí que son interesantes en entornos controlados (nuestro laboratorio con nuestro equipo de análisis) donde sabemos qué estamos haciendo y qué estamos ejecutando.

Ejemplo: Script de bloqueo *software*

Un script muy sencillo que podemos utilizar desde Sistemas Operativos Windows para bloquear la escritura de los puertos USB es a través del Registro de Windows modificando las siguientes claves:

Para bloquear la escritura

[HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\StorageDevicePolicies]

"WriteProtect"=dword:00000001.

Para volver a permitir la escritura

[HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\StorageDevicePolicies]

"WriteProtect"=dword:00000000

Un tipo especial de bloqueadores por software serían las **distribuciones Linux forenses.** Estas distribuciones incluyen un modo de arranque en el que el sistema

© Universidad Internacional de La Rioja (UNIR)

operativo no monta los dispositivos conectados al equipo y, por lo tanto, no puede escribir sobre ellos.

Además, suelen incluir la opción de montar los dispositivos en modo solo lectura para poder revisar su contenido sin alterarlo.

Este tipo de distribuciones suele utilizarse cuando necesitamos adquirir el contenido del disco duro de un equipo y no podemos extraerlo o no tenemos los adaptadores específicos para su conexión con un bloqueador contra escritura por hardware.

Algunas de las distribuciones Linux que podemos utilizar para bloquear la escritura son:

- Kali Linux (https://www.kali.org/).
- Parrot Security OS (https://www.parrotsec.org/).
- Tsurugi Linux (https://tsurugi-linux.org/).

Borrado seguro

Cuando vamos a grabar sobre un dispositivo, debemos asegurarnos de que el dispositivo destino esté completamente limpio; especialmente, si vamos a realizar un clonado, ya que, de otro modo, se podría poner en duda si los datos preexistentes provienen de la adquisición.

El borrado seguro es un método de borrado que sobrescribe la información original de forma que esta no pueda ser recuperada.

El método más común consiste en la sobreescritura de la información original con ceros, aunque también es posible sobrescribirla con cualquier otro valor o valores aleatorios.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

Un borrado **seguro se puede realizar sobre todo un dispositivo** (con *software* específico), sobre una partición concreta (con un simple formateo lento) o sobre el espacio libre (lo que impediría la recuperación de archivos).

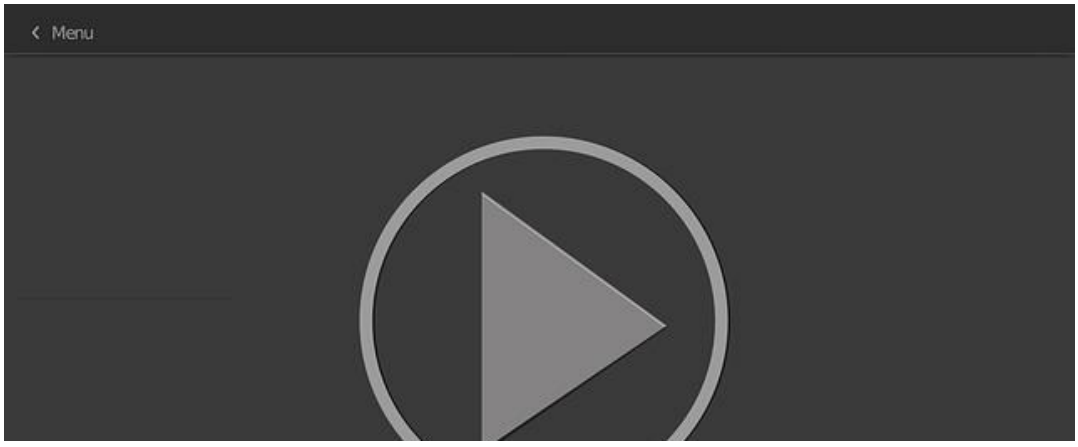
Como forenses realizaremos un **borrado seguro en los siguientes casos:**

- Cuando vayamos a desechar un dispositivo.
- Cada vez que un dispositivo que hayamos utilizado para almacenar información sobre un caso vaya a ser reutilizado en un nuevo caso.
- Cuando vayamos a utilizar un dispositivo como destino de un clonado.

El borrado seguro lo podemos hacer con distintos programas entre los que los más utilizados son:

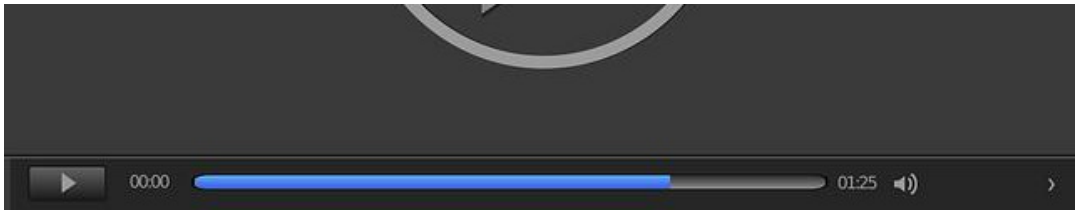
- Encase Forensics Imager (Windows).
- dd / dc3dd (Linux y MacOS).
- R-Wipe & Clean (Windows y MacOS).
- HDShredder (Windows).

En el siguiente vídeo, hablaremos sobre el borrado seguro y el bloque contra escritura:



© Universidad Internacional de La Rioja (UNIR)

Ideas clave



Accede al vídeo:

https://unir.cloud.panopto.eu/Panopto/Pages/Embed.aspx?id=71a3d98a-a49e-4f10-b60f-b0c900b60bf5

© Universidad Internacional de La Rioja (UNIR)

3.5. Conceptos previos

A continuación, vamos a tratar unos conceptos previos importantes a la hora de entender y de realizar una adquisición de evidencias digitales.

Imagen forense vs clonado

Hemos visto previamente cómo la adquisición de evidencias digitales consiste en la copia de estas.

Esta copia se puede obtener en dos formatos diferentes: **la imagen forense y el clonado forense.**

- Una **imagen forense** es una copia exacta de un dispositivo físico que es almacenada en un archivo, el cual puede ser guardado en cualquier tipo de dispositivo capaz de almacenar archivos.
- Por su parte, un **clonado** es una copia exacta *(«bit a bit»)* de un dispositivo físico en otro dispositivo físico similar. De esta forma, el dispositivo original y el dispositivo clonado son idénticos en cuanto a contenido y estructura.

Notar que, habitualmente, se emplean los términos imagen forense y clonado de forma indistinta, si bien —como hemos visto anteriormente— nada más lejos de la realidad, puesto que son términos antagónicos.

Una imagen forense es más versátil que un clonado, ya que un archivo es más fácil de distribuir, copiar, etcétera. además, la imagen forense permite añadir metadatos referentes al caso, comprensión, redundancia para tolerancia a fallos, etc. y es posible almacenar varias imágenes en un solo dispositivo.

Además, necesitaremos dispositivos individuales para cada clonado que queramos realizar, y el tamaño de dicho dispositivo deberá ser mayor o igual que el original, y debe encontrarse borrado mediante un borrado seguro. La ventaja del clonado es

© Universidad Internacional de La Rioja (UNIR)

que no necesitamos ningún tipo de programa para cargarlo, y podremos utilizar exactamente el mismo hardware original en la investigación si fuera necesario. Los clonados se suelen utilizar cuando se trata de hardware muy específico como, por ejemplo, sistemas de CCTV (circuito cerrado de televisión).

Adquisición en caliente vs en frío

Decimos que estamos realizando una adquisición en *frío (post-mortem o Traditional Acquisition)* cuando el dispositivo a analizar se encuentra apagado o desconectado y lo adquirimos «manteniendo ese estado».

> Ejemplos de adquisición en frío
>
> Un dispositivo de almacenamiento externo (flashdrive USB) desconectado que conectamos a nuestro equipo bloqueando la escritura.
>
> El disco duro de un ordenador que hemos extraído y adquirimos conectándolo a nuestro equipo bloqueando la escritura.
>
> El disco duro de un ordenador que se encontraba apagado (o que hemos apagado), y que iniciamos con una distribución Linux forense.

Además, decimos que estamos realizando una adquisición en caliente (Live Response Acquisition) cuando el dispositivo a analizar se encuentra encendido y lo adquirimos mientras se encuentra encendido.

> **Ejemplos de adquisición en caliente**
>
> Adquisición de memoria RAM de un ordenador encendido.
>
> Adquisición de disco duro de un servidor encendido.

© Universidad Internacional de La Rioja (UNIR)

Mientras que las evidencias volátiles, por su propia naturaleza, solo las podremos adquirir en caliente, las evidencias no volátiles las podemos adquirir en frío (con el equipo apagado) o en caliente (equipo encendido), dependerá de cómo nos lo encontremos.

Adquisición física vs lógica

Si atendemos a la estructura lógica del dispositivo a adquirir, se presentan de nuevo dos posibilidades: la adquisición física y la lógica.

Cuando se mantiene la estructura lógica completa —esto es, toda la información contenida en el dispositivo—, se copia exactamente igual del origen al destino, decimos que hemos realizado una adquisición física.

No importa si estamos haciendo una imagen forense o un clonado, en una adquisición a nivel físico del primer al último bit almacenado en el dispositivo (en el caso de un disco duro del primer al último sector) serán copiados.

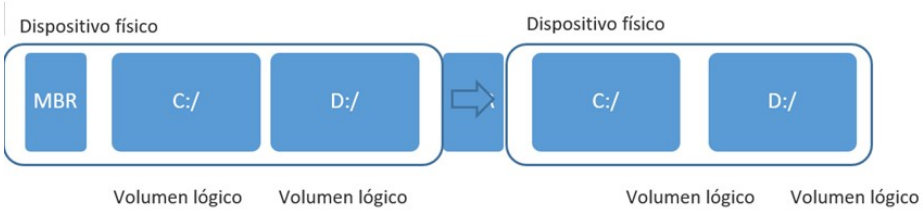


Figura 4. Adquisición lógica. Fuente: elaboración propia.

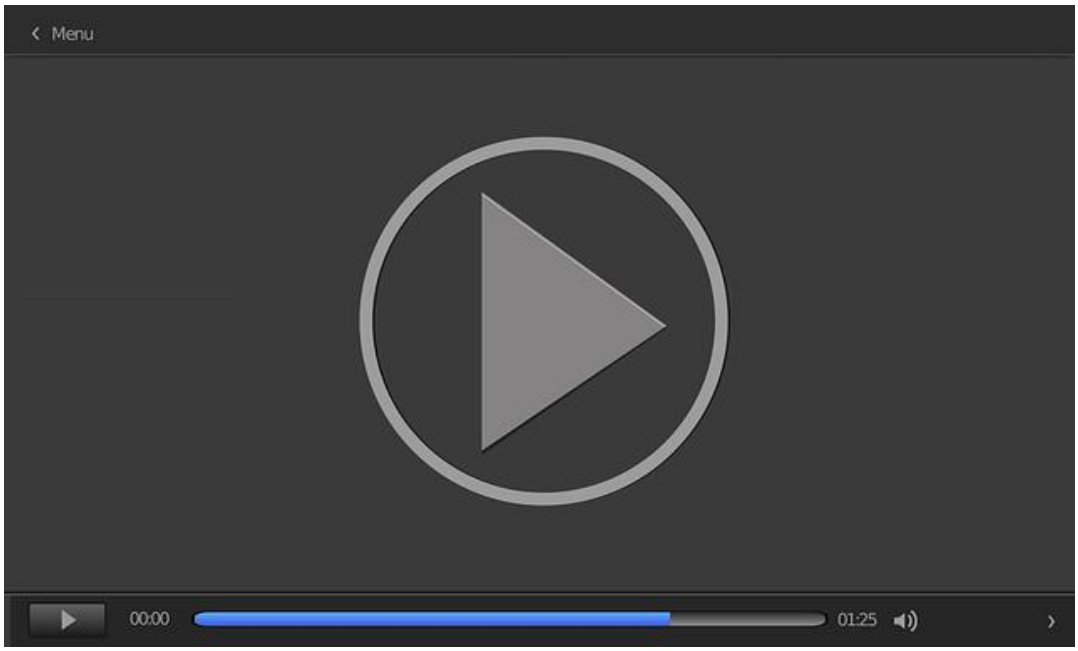
Cuando la copia realizada se limita a un volumen o a una parte de este (un conjunto de archivos o carpetas o a una Base de Datos concreta, por ejemplo), decimos que hemos realizado una adquisición lógica.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

Una adquisición lógica únicamente se puede hacer en **formato imagen forense,** nunca podremos hacer un clonado, ya que un clonado es una copia idéntica de un dispositivo de almacenamiento en otro dispositivo similar y, por tanto, de toda la estructura.

En el siguiente vídeo hablaremos sobre la adquisición remota en un servidor Linux:



Accede al vídeo:

https://unir.cloud.panopto.eu/Panopto/Pages/Embed.aspx?id=e3da283c-d2ef-4375-a746-b0c900b5ac1f

En el siguiente vídeo, hablaremos sobre las EFW Tools:



© Universidad Internacional de La Rioja (UNIR)

Ideas clave



Accede al vídeo:

https://unir.cloud.panopto.eu/Panopto/Pages/Embed.aspx?id=bea096f6-58b7-4148-b73c-b0c900b5f555

© Universidad Internacional de La Rioja (UNIR)

3.6. Recolección y adquisición de evidencias digitales

Para todo el procedimiento de recolección y adquisición, trabajaremos según la **normativa ISO 27037:2016** con el fin de realizar todo el procedimiento con las mayores garantías.

Dicha norma proporciona una serie de directrices para la identificación, recolección, adquisición y preservaciones de evidencias digitales. Vamos a ver cada uno de los pasos a realizar.

Recolección vs adquisición

Lo primero que vamos a hacer es distinguir entre los conceptos de recolección y adquisición. En este sentido, según la propia norma ISO 27037, la **recolección** es: «El proceso de recopilación de los elementos físicos que pueden contener una potencial evidencia digital». (p. 2). En pocas palabras, estamos hablando del paso previo de identificación de los dispositivos que puedan contener una evidencia digital y el posterior traslado al laboratorio para ser analizados allí.

La **adquisición** es la obtención de la información contenida en esos contendores de evidencias digitales. Esta labor puede ser realizada en el laboratorio tras la recolección o in situ, de modo que el dispositivo se puede quedar en su lugar original, en sede judicial o en notaría, y nosotros podemos analizar la información adquirida.

Posteriormente, la norma analiza cinco escenarios diferentes:

- Recolección en frío y en caliente.
- Adquisición en frío y en caliente.
- Supuestos especiales.

© Universidad Internacional de La Rioja (UNIR)

Para cada uno de ellos marca un flujo de trabajo distinto en función de las circunstancias que nos encontremos.

Recolección en frio

La recolección en frío se dará cuando encontremos un equipo apagado. A tal efecto la misma norma marca el siguiente esquema:

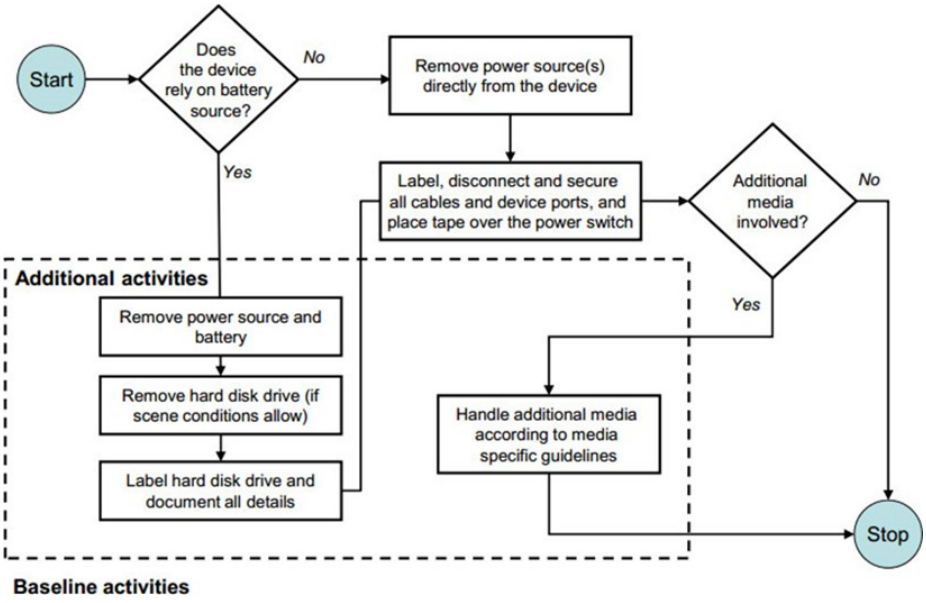


Figura 5. Recolección en frio. Fuente: ISO 27037 p. 24.

Cabe destacar que este proceso debe ser realizado para todos y cada uno de los dispositivos que nos encontremos cuidando para que a cada uno de ellos le apliquemos todos los pasos que vamos a ver que sean necesarios. El caso más genérico puede ser el de un ordenador portátil donde, probablemente, deberemos aplicar todos los pasos; mientras que, en un disco duro, externo la labor se simplifica bastante.

- Primeramente, hay que ver si el dispositivo funciona con algún tipo de batería que pueda ayudarle a mantener su estado o a ser arrancado en un momento dado de manera accidental. Si este es el caso, se debe desconectar dicha batería. En

© Universidad Internacional de La Rioja (UNIR)

muchas ocasiones, la desconexión de la batería implica la manipulación del dispositivo. En este caso, si no hay inconveniente para ello, es muy probable que sea conveniente aprovechar para extraer el disco duro del portátil, ya que tendremos que desconectarlo totalmente. Así, extraeríamos dicho disco duro, lo etiquetaríamos, documentaríamos completamente lo que hemos hecho y continuaríamos el procedimiento con el resto de los elementos recopilados.

- Lo siguiente que hay que realizar es desconectar el cable de alimentación del dispositivo para conservar el estado de este. Una vez hecho esto, se procede a desconectar el resto de los cables identificando cada uno, fotografiando, etc. para asegurarnos de la configuración que teníamos. Además, para mayor seguridad, pondremos cinta sobre el interruptor para que, así, cualquiera que se acerque al equipo tenga claro que dicho botón se debe de utilizar con toda la precaución, evitando que alguien pueda pulsarlo accidentalmente. Por supuesto, todo el procedimiento se habrá de documentar.

- Analizaremos a continuación si hay otros medios relacionados, como otros discos duros, y actuaremos del mismo modo. Es muy importante incidir en este aspecto, ya que algo que suele suceder es que el analista —muchas veces, por la prisa— no examina, por ejemplo, si existen medios dentro de las unidades de DVD del equipo. Si existe un CD, DVD, etc. que sea relevante para el caso, y no es inventariado de la manera correcta, cabe la posibilidad que no sea admitido durante el juicio.

- Una vez hayamos terminado, estaremos en condiciones de continuar la recolección de los diferentes elementos. Si ya hemos terminado dicha recolección, pasaremos al momento de la adquisición.

Recolección en caliente

El esquema de la recolección en caliente es el que se puede ver más adelante.

© Universidad Internacional de La Rioja (UNIR)

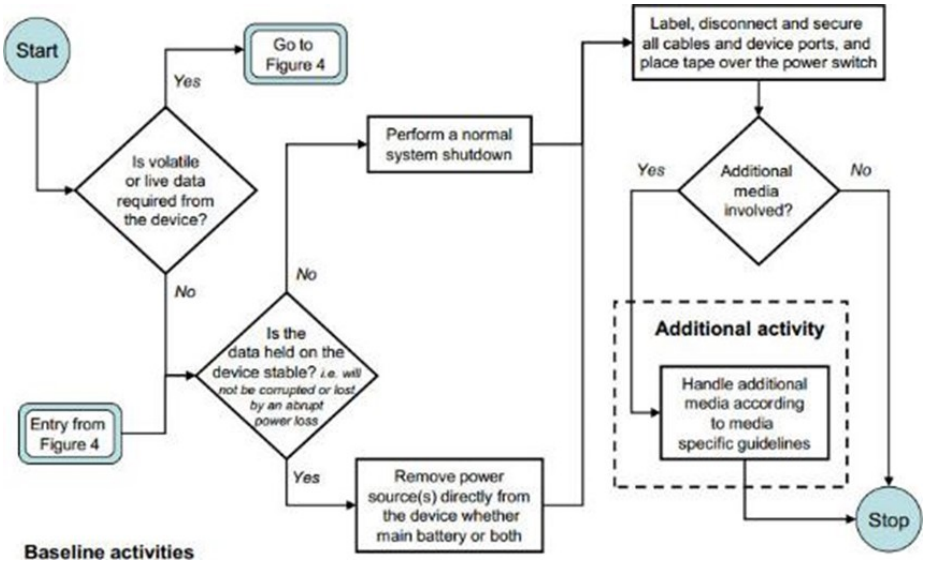


Figura 6. Recolección en caliente. Fuente: ISO 27037 p. 22.

Como veremos, esta recolección es algo más compleja que en el caso de realizarlo para dispositivos apagados, ya que ahora deberemos tener en cuenta, además, las evidencias volátiles.

- En primer lugar comenzamos el proceso viendo si existen datos volátiles que debamos recopilar (RAM, tablas de procesos, etc.). En el caso de que existan, vamos a lo que en la imagen se marca como Figura 4 que, simplemente, se trata del proceso de adquisición en caliente que más adelante veremos.

- En el caso de que no haya datos volátiles, lo siguiente que tenemos que ver es si los datos que residen en el equipo (por ejemplo, en su disco duro) se encuentran estables, esto es, si al interrumpir la corriente no se ven comprometidos. A veces, esto es así con sistemas lentos, antiguos o transaccionales, en los que, hasta que no se finalice la transacción, los datos no se quedan finalmente grabados.

- Si no creemos que los datos vayan a sufrir ningún riesgo, en ese caso procedemos a un apagado forense, que consiste en desconectar directamente la batería o el cable de alimentación e interrumpir de forma abrupta la corriente. Esto se hace así porque, de ese modo, garantizamos que la información queda en el mismo estado en el que

© Universidad Internacional de La Rioja (UNIR)

se encuentra, de modo que, por ejemplo, la memoria de paginación, archivos temporales, etc. no se pierde. Otra razón para no hacer un apagado limpio es porque muchas veces se ejecutan scripts o programas de limpieza al realizar el apagado, bien sea como en el caso de equipos públicos como cibercafés, para dejarlo preparado para otras personas en el próximo reinicio, o bien sea porque se pretende borrar todo tipo de huella de actividad. En este caso, si apagamos el equipo abruptamente, estos programas no se ejecutarán.

- Por el contrario, en el caso en el que sospechemos que un apagado de este tipo puede suponer que los datos se corrompan, no nos quedará más remedio que realizar un apagado limpio del sistema, a sabiendas de que cabe la posibilidad de que estemos perdiendo parte de información.

- Una vez en este punto, desconectaremos el resto de los cables, dispositivos, etc. Etiquetaremos y fotografiaremos todo convenientemente para, luego, poder recuperar todas las conexiones si fuera necesario y, por supuesto, documentaremos todo el proceso realizado.

Ya tenemos nuestro equipo apagado y, en el caso de que haya sido necesario, hemos adquirido las evidencias volátiles. Solo falta —como en el caso de la adquisición en frío— ver si existen otros dispositivos o medios asociados (pendrives, CDs, DVDs, otros discos duros, etc.) para extraerlos, documentarlos y tratarlos como es oportuno.

Adquisición en frío

Recordamos que la adquisición es una copia exacta del contenido de un medio de almacenamiento. En el caso de tener que adquirir dispositivos apagados, esto es, en frío, vamos a trabajar del siguiente modo:

© Universidad Internacional de La Rioja (UNIR)

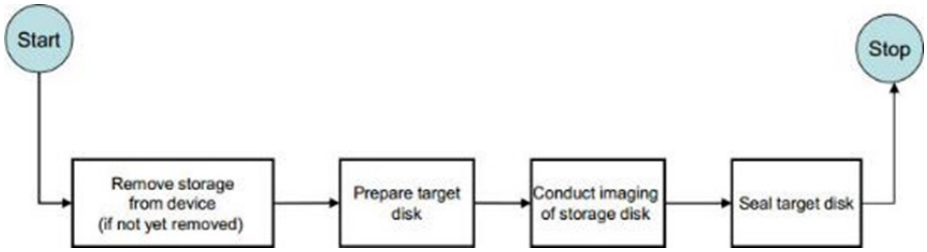


Figura 7. Adquisición en frio. Fuente: ISO 27037 p. 27.

- Inicialmente, **extraemos el dispositivo de almacenamiento del equipo contenedor** (como, por ejemplo, un disco duro de un ordenador). En el caso de un dispositivo externo o previamente extraído, continuamos al siguiente paso.

- **Prepararemos el disco destino.** La preparación del disco destino supone su sanitización, esto es, el borrado profundo o forense de toda la información contenida en él para que no exista ninguna duda de que la información que va a contener a partir de este momento va a pertenecer a nuestro caso en cuestión. En este punto podemos hacer de nuevo dos divisiones:

•Si pretendemos extraer una imagen, podremos utilizar un disco para varias imágenes y, por tanto, necesitaremos menos espacio de almacenamiento.

•En el caso de querer realizar clonados, necesitaremos un disco por cada dispositivo a clonar, y será especialmente importante la sanitización.

- Luego, será el momento de **realizar nuestra imagen o clonado.** Para ello, conectaremos el dispositivo origen y destino al equipo que vayamos a utilizar para realizar la adquisición (una clonadora o un ordenador), y comenzaremos nuestra operación. En el caso de que el dispositivo sea un dispositivo forense como una clonadora, podremos realizar la conexión del disco origen directamente, pero, en el caso de que sea un equipo multipropósito, corremos el riesgo de alterar de forma accidental su información, por lo que utilizaremos un bloqueador de escritura. Si no poseemos un dispositivo *hardware* de este tipo, siempre podremos realizarlo a través de configuración *software.*

© Universidad Internacional de La Rioja (UNIR)

- Una vez realizada la copia, documentaremos todo lo realizado, sellaremos el disco de destino, y lo custodiaremos conjuntamente con la documentación.

Adquisición en caliente

Vamos a continuación a ver la adquisición de dispositivos encendidos. En este caso es necesario realizar más operaciones y más verificaciones, como vamos a ver a continuación.

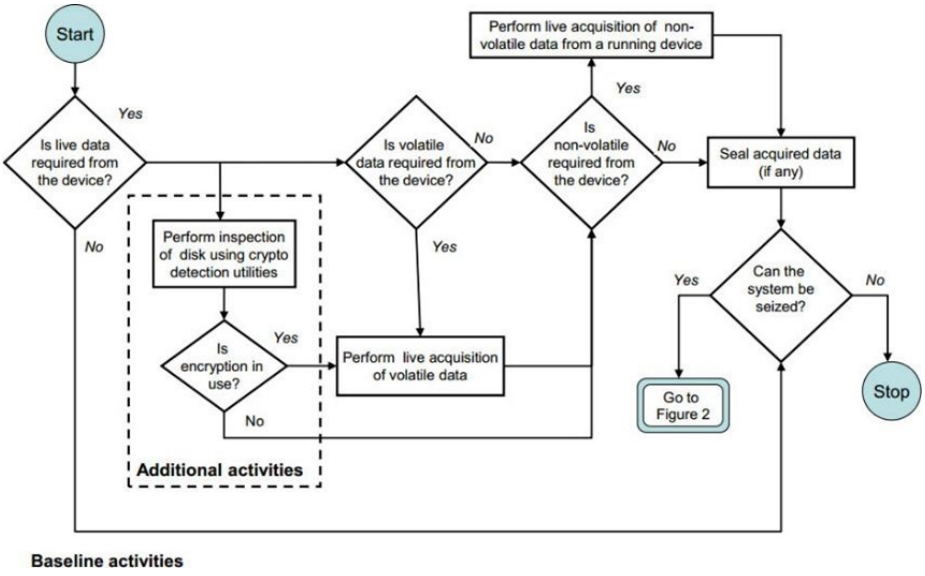


Figura 8. Adquisición en caliente. Fuente: ISO 27037 p. 26.

- Primero veremos si tenemos datos vivos que sea necesario adquirir en el equipo. En el caso de que no sea así, y por precaución, podemos plantearnos llevarnos el equipo. Si no podemos, aquí termina nuestra labor; pero, si podemos, volveremos al proceso de recolección de dispositivos encendidos, y operaremos tal y como en este punto tratábamos de cara a apagar el equipo y poder llevárnoslo.

- En el caso de que —en efecto— existan datos que queramos adquirir en caliente, lo primero que haremos es mirar si existen datos encriptados usando herramientas a tal fin. Si se está utilizando encriptación, en este caso deberemos de realizar adquisición en vivo primero de los datos encriptados volátiles y, luego, de los datos encriptados no volátiles. Esto es así como sabemos porque es posible que si

© Universidad Internacional de La Rioja (UNIR)

apagamos el equipo ya no podamos acceder a dichos datos encriptados.

- En el caso en el que los datos no se encuentren encriptados, inicialmente, buscaremos información volátil para adquirir y la adquirimos. Recordamos que para adquirir información en caliente necesitaremos un software específico que deberemos ejecutar en el equipo que estamos adquiriendo. Este software debemos proporcionarlo nosotros para asegurarnos de que no se encuentra comprometido. Será habitualmente un software forense en una versión live o standlalone que permita ser ejecutado sin necesidad de ser instalado para minimizar nuestro impacto.

- Una vez hemos concluido con las evidencias volátiles, nos planteamos si necesitamos adquirir los datos no volátiles. En este punto podremos hacer la adquisición o bien analizar si queremos llevarnos el dispositivo, en cuyo caso, volveremos a la fase de recolección de evidencias en caliente para apagarlo de forma conveniente. Una vez en nuestro laboratorio, extraeríamos el disco duro y realizaríamos una adquisición en frío.

- Una vez tengamos todas las evidencias necesarias extraídas, solo nos quedaría sellar los dispositivos usados para la adquisición, documentar todo el proceso, adjuntar de nuevo la documentación a dichos dispositivos y custodiar el conjunto.

Preservación de evidencias

Como se ha comentado anteriormente, una vez adquiridas las evidencias, es necesario preservarlas de modo que se respete la cadena de custodia, esto es, que aquello que vamos a analizar sea exactamente igual a lo que nos encontramos en origen y que no haya sufrido ninguna alteración desde el punto de la adquisición hasta el del análisis. Para ello, en el momento de la adquisición en frío, tomamos precauciones como el bloqueo de escritura. Pero ¿cómo garantizar más allá? ¿Qué pasa en el caso de la adquisición en caliente?

Para verificar que lo analizado es una copia exacta de la evidencia original, o que la integridad de dicha copia se mantiene a lo largo de todo el proceso de análisis,

© Universidad Internacional de La Rioja (UNIR)

hacemos uso de las funciones hash.

Recordemos que una función hash nos sirve para comparar información arrojando valores muy diferentes en el caso de que haya una mínima variación en la entrada. Esto es especialmente útil para verificar la no alteración de la información.

De ese modo, distinguiremos dos procedimientos, en frío y en caliente.

- En frío: la información a adquirir permanece inalterada tras la adquisición, ya que podemos utilizar dispositivos para proteger contra escritura. En ese sentido podremos garantizar que aquello que vamos a adquirir será exactamente igual a lo adquirido mediante el cálculo del hash antes y después de dicho procedimiento. Lo haremos de la siguiente manera:

  - Realizamos un hash a la información a adquirir (HA1) antes de la adquisición.
  - Realizamos un hash a la información a adquirir (HA2) después de la adquisición.
  - Realizamos un tercer hash a la información adquirida (HB).
  - Si los tres coinciden quiere decir que la información origen no se ha alterado y que la información adquirida es exactamente igual a la información origen.



Figura 9. Procedimiento de preservación en frío. Fuente: elaboración propia.

Además, para verificar en cualquier momento del análisis que lo que se está analizando es lo mismo que se obtuvo de la evidencia original, solo tenemos que realizar, nuevamente, un *hash* a la evidencia objeto del análisis y compararlo con el primer hash de la evidencia original (HA1). Si son idénticos estamos analizando una

© Universidad Internacional de La Rioja (UNIR)

copia exacta de la evidencia original, mientras que, si son distintos, la evidencia que estamos analizando ha sido alterada.

Este proceso de preservación de la integridad e identidad de las evidencias, programas como las suites forenses Autopsy, EnCase o Forensic ToolKit, lo realizan de manera transparente al analista, y muestran una advertencia en el caso de que dichos valores no coincidan.

Ahora bien, el proceso de preservación de la integridad de las evidencias varía cuando realizamos **adquisiciones «en caliente».** El problema de este tipo de adquisiciones es que, en la mayoría de los casos, no es posible bloquear contra escritura el origen (por ejemplo, la memoria RAM), por lo que se va a producir una alteración imposible de evitar en la fuente original de información. El hacer un hash a la evidencia original, por tanto, carecería de sentido, ya que *a priori* sabemos que no coincidirá.

El proceso de adquisición y preservación de la integridad cuando se realiza una adquisición en caliente se limitaría a realizar el *hash* al resultado de la adquisición y utilizar dicho *hash* como referencia para compararlo y, así, evitar futuras alteraciones.



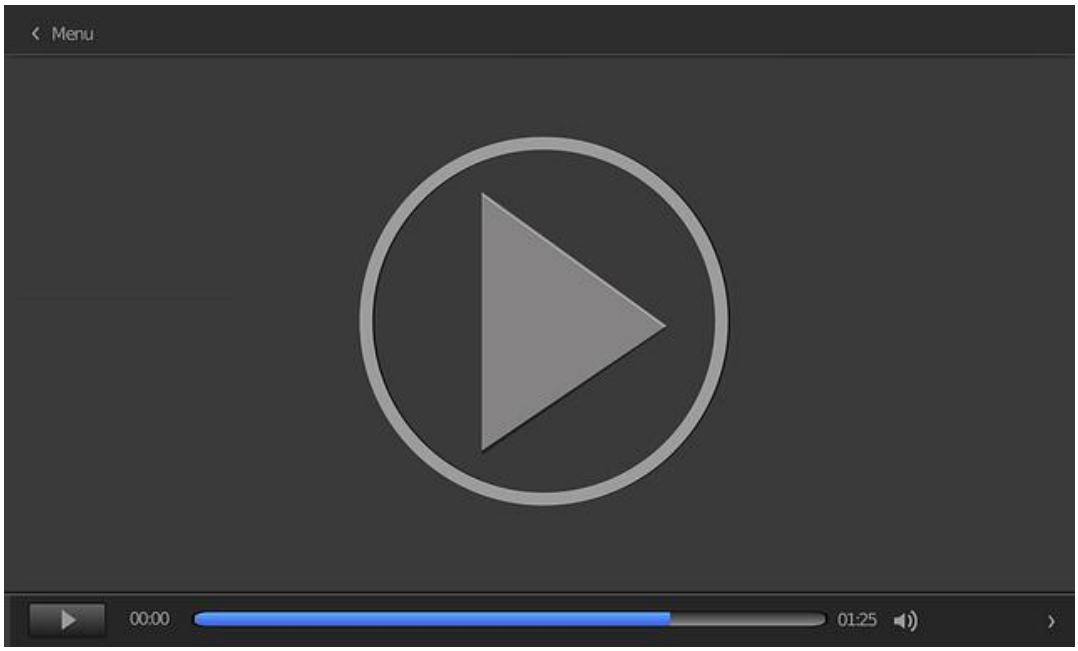
Figura 10. Procedimiento de preservación en caliente. Fuente: elaboración propia.

En este caso el procedimiento *hash* no nos va a servir para garantizar el origen en la cadena de custodia, ya que no podemos asegurar que la información original sea igual a la adquirida. El único modo de hacer esto será mediante un tercero de confianza que documente ese proceso. Para ello, se suele utilizar un fedatario público (secretario judicial), notario o cualquier otro mecanismo que pueda ser aceptado como tercero de confianza.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

En el siguiente vídeo, hablaremos sobre la adquisición de la memoria RAM en Windows:



Accede al vídeo:

https://unir.cloud.panopto.eu/Panopto/Pages/Embed.aspx?id=529fafcd-c8fc-4704-9edd-b0c900b62fbb

© Universidad Internacional de La Rioja (UNIR)

3.7. Procedimientos especiales de adquisición

Anteriormente, hemos comentado que la normativa ISO/IEC 27037 diferencia entre dos tipos distintos de adquisición. Esta norma también hace referencia a supuestos especiales en los que los procedimientos de adquisición y/o recolección no tienen por qué seguir las directrices indicadas. Estos supuestos especiales son: los **dispositivos críticos (**por ejemplo, servidores que no pueden ser apagados), las **adquisiciones parciales y los dispositivos de almacenamiento.**

- La normativa ISO/IEC 27037 identifica la **adquisición parcial** de información como un supuesto especial dentro de los tipos de adquisición. Una adquisición parcial puede ser necesaria en diversos casos:

  - Cuando el tamaño (almacenamiento) del dispositivo a adquirir es muy elevado, y se hace imposible adquirirlo completamente. Por ejemplo, servidores de bases de datos.

  - Cuando el sistema es crítico, y no puede ser apagado.

  - Cuando solo una parte de la información es relevante para la investigación. Ejemplo: cuando nos interesan únicamente los correos electrónicos de un equipo.

  - Cuando legalmente (por ejemplo, por decisión de un juez) se nos limita el alcance de la adquisición.

Cuando es necesario realizar una adquisición parcial, el procedimiento a seguir (de manera simplificada) sería:

- Identificar los archivos, las carpetas o demás elementos que contienen la información relevante.

- Realizar una adquisición lógica de estos elementos.

© Universidad Internacional de La Rioja (UNIR)

- También, la norma identifica la adquisición de dispositivos críticos como un supuesto especial dentro de los tipos de adquisición. En algunos casos los dispositivos no pueden ser apagados dada su criticidad. Estos sistemas, como servidores de centros de datos que pueden dar servicio a clientes no relacionados con la investigación, sistemas de apoyo médicos, etc. deben mantenerse operativos todo el tiempo con el objetivo de evitar un daño mayor.

En estas oportunidades seguiremos las directrices explicadas para la adquisición de dispositivos encendidos o la adquisición parcial de información.

- Por último, identifica la adquisición de los dispositivos de almacenamiento como un supuesto especial dentro de los tipos de adquisición. En la escena de un incidente, es normal encontrar distintos tipos de dispositivos de almacenamiento como pendrives, tarjetas SD, etc. Normalmente, estos dispositivos son los menos volátiles y, por lo tanto, son los de menor prioridad a la hora de su recolección y adquisición, aunque esto no significa que no sean importantes de cara a la investigación.

Para el tratamiento de este tipo de dispositivos se debe:

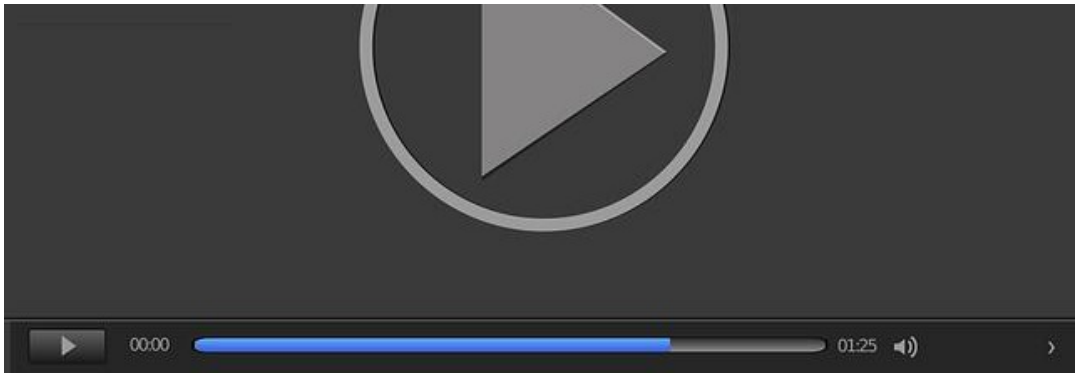
- Documentar la ubicación del dispositivo (conectado por USB, en una bahía extraíble, etc.) y los datos identificativos de este (marca, modelo, número de serie, etc.).
- Decidir si recolectar o adquirir en el momento el dispositivo.
- Etiquetar el dispositivo y los distintos elementos que pudieran estar asociados a él, como carcasas o cables.

En el siguiente vídeo, hablaremos sobre el File carving con Photorec y discos SSD:



© Universidad Internacional de La Rioja (UNIR)

Ideas clave



Accede al vídeo:

https://unir.cloud.panopto.eu/Panopto/Pages/Embed.aspx?id=612dadb7-3b15-458b-b88d-b0c900b6a342

© Universidad Internacional de La Rioja (UNIR)

3.8. Referencias bibliográficas

Organización Internacional de Normalización. (2016). Directrices para la identificación, recopilación, adquisición y preservación de la evidencia digital (ISO/IEC 278037). https://www.une.org/encuentra-tu-norma/busca-tu-norma/norma?c=N0057481.

Hayes, D. (2020). *Practical Guide to Digital Forensics Investigations.* Pearson IT Certification.

Oettinger, W. (2020). *Learn Computer Forensics: A beginner's guide to searching, analyzing, and securing digital evidence.* Packt Publishing.

Parasram, S. V. N. (2017). *Digital Forensics with Kali Linux: Perform data acquisition, digital investigation, and threat analysis using Kali Linux tools*. Packt Publishing.

Brezinski, D., y Killalea, T. (2002). *Guidelines for Evidence Collection and Archiving*. http://www.ietf.org/rfc/rfc3227.txt.

Henry, P. (2009). *Best Practices. In Digital Evidence Collection.* http://computer-forensics.sans.org/blog/2009/09/12/best-practices-in-digital-evidence-collection.

© Universidad Internacional de La Rioja (UNIR)

DFRWS Acquiring forensic evidence from infrastructure-as-a-service cloud computing

Dykstra, J. y Sherman, A. (2012). Acquiring forensic evidence from infrastructure-as-a-service cloud computing. Digital Investigation, 9, El Sevier. S90-S98. https://josiahdykstra.com/wp-content/uploads/2016/06/Dykstra-acquiring_forensic_evidence_from_infrastructure-as-a-service_cloud_computing.pdf

Este documento, publicado en la DFRWS (Digital Forensics Research Conference) de 2012, trata sobre las técnicas y las posibles formas de afrontar la adquisición de evidencias en remoto.

© Universidad Internacional de La Rioja (UNIR)

On the Use of Hash Functions in Computer Forensics

Baier, H. (2012). On the Use of Hash Functions in Computer Forensics. En Autor, Computer Forensics. Darmstadt: CASED. Disponible en el aula virtual en virtud del artículo 32.4 de la Ley de Propiedad Intelectual.

Es recomendable la lectura del capítulo 8 del libro Computer Forensics, publicado por CASED. En este texto se habla sobre el uso de las funciones hash en el ámbito de la informática forense. Está disponible en el aula virtual.

© Universidad Internacional de La Rioja (UNIR)

Directrices para la identificación, recogida, adquisición y preservación de evidencias electrónicas

UNE-EN ISO/IEC 27037:2016 (Ratificada). Tecnología de la información, técnicas de seguridad, directrices para la identificación, recogida, adquisición y preservación de evidencias electrónicas (ISO/IEC 27037:2012). (Ratificada por AENOR en diciembre de 2016.).

Se recomienda la lectura de este estándar que renueva directrices anteriores con recomendaciones más acorde a la tecnología actual.

© Universidad Internacional de La Rioja (UNIR)

Test

1. ¿Cómo aseguramos el bloqueo contra escritura de una evidencia que vamos a adquirir en frío?

A. Mediante dispositivos hardware.

B. Nunca es posible bloquear totalmente contra escritura.

C. Mediante bloqueadores hardware o mediante bloqueo software a través de programas o scripts o bien cargando una distro Linux forense.

D. Todas las anteriores son ciertas.

2. ¿Qué hemos de tener en cuenta al acotar la escena del crimen?

A. Aquellos equipos que han sufrido directamente el incidente.

B. Los equipos que han sufrido directamente el incidente y otros que puedan estar relacionados.

C. Se debe recoger todo el material posible, pues ello nos ayudará a realizar un mejor análisis.

D. Los equipos que han sufrido directamente el incidente y todos los servidores con los que este interactúe.

3. ¿Cuáles de los siguientes son algoritmos hash?

A. SHA1.

B. SHA3.

C. MD5.

D. Todas las anteriores.

4. ¿Cuándo debemos realizar una adquisición en caliente?

A. Cuando existen evidencias volátiles que queremos conservar.

B. Cuando se trata de un equipo que no se puede apagar.

C. Cuando nos encontramos con un disco duro cifrado.

D. Todas las anteriores son correctas.

© Universidad Internacional de La Rioja (UNIR)

5. ¿Cuáles son las ventajas de la imagen forense frente al clonado?

A. No es necesario ningún programa para trabajar con imágenes.

B. Puedo tener varias imágenes en un mismo dispositivo de almacenamiento.

C. En las imágenes forenses puedo comprimir datos, añadir metadatos, redundancia, etc.

D. La B y la C son ciertas.

6. Cuando adquirimos un disco duro completo, con todas sus particiones y la tabla de particiones, estamos realizando:

A. Una adquisición en caliente.

B. Una adquisición lógica.

C. Una adquisición física.

D. Una imagen en caliente.

7. Según la ISO 27037, hay que hacer una adquisición parcial:

A. Cuando el tamaño del dispositivo a adquirir es muy grande.

B. Todas son ciertas.

C. Cuando el juez nos limita la información a adquirir.

D. Cuando solo una parte de la información es relevante.

8. «El proceso de recopilación de los elementos físicos que pueden contener una potencial evidencia digital» es la definición de:

A. Adquisición.

B. Clonado.

C. Recolección.

D. Imagen forense.

© Universidad Internacional de La Rioja (UNIR)

9. Según la ISO 27037, ¿cuál de los siguientes no es un supuesto especial?

A. Adquisición parcial.

B. Adquisición de un ordenador portátil.

C. Dispositivo de almacenamiento.

D. Dispositivo crítico.

10. ¿Cuáles de las siguientes propiedades no pertenece a la función hash?

A. Inyectividad.

B. Compresión.

C. Bajo coste computacional.

D. Bidireccionalidad.

© Universidad Internacional de La Rioja (UNIR)